

PRACTICAL CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

# NIST CYBERSECURITY FRAMEWORK 2.0

## Practical GRC, Implementation, Evidence, and Open-Source Tools

*A working manual for managers, junior analysts, students, career changers, and cybersecurity teams*

**Alberto (Al) Leiva**

First Edition • July 2026

**Inside:** All 106 CSF Core outcomes • Profiles • Tiers • GRC • supply chain • evidence • control testing  
• open-source tools • labs • career preparation

## Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

Purpose: Free, practical education for managers, junior analysts, students, career changers, risk professionals, and cybersecurity practitioners.

### Educational notice

This manual provides general educational information. It does not create certification, legal compliance, an audit opinion, or a guarantee of security. Organizations must tailor the NIST CSF to their mission, risks, obligations, risk appetite, resources, technologies, and stakeholders. Use current official sources and qualified legal, risk, privacy, safety, audit, and technical advice for real decisions.

### Ethical and authorized use

Use technical tools only on systems, applications, networks, cloud accounts, and data that you own or are specifically authorized in writing to assess. Use fictional, synthetic, or approved data in training. Technical ability does not create permission.

## Preface

*A welcoming introduction to practical cybersecurity risk management.*

Cybersecurity work can look like a collection of products, alerts, policies, and technical tasks. The NIST Cybersecurity Framework gives those activities a shared language. It helps leaders explain what outcomes matter, helps managers set priorities, and helps practitioners connect daily work to organizational risk.

CSF 2.0 is deliberately flexible. It does not tell every organization to buy the same tool, implement the same control, or reach the same Tier. It describes outcomes. A hospital, manufacturer, school, bank, startup, government agency, and nonprofit can use the same Core while choosing different priorities and implementations.

This manual follows a methodology-first approach. A framework spreadsheet is useful only when scope is accurate. A green dashboard is useful only when evidence is reliable. A scanner result is useful only when someone validates, prioritizes, corrects, and retests it. Managers remain accountable for decisions; analysts make those decisions better by gathering complete facts and communicating clearly.

## How to Use This Manual

Managers should begin with Chapters 1–3, 10–17, and the templates in Chapter 22.

Junior analysts should study the six Function chapters, verification method, tools, laboratory, and interview preparation.

Technical teams should map findings to assets, risks, CSF outcomes, implementation, owners, evidence, and corrective action.

Legal, privacy, safety, operational technology, and business teams should review decisions that affect their responsibilities.

**True Word contents:** The chapter guide below contains edition-specific page numbers after final rendering. The document also contains a native Word TOC field. After editing, right-click it and select Update Field, then Update entire table.

## Table of Contents

|                                                          |    |
|----------------------------------------------------------|----|
| Publication and Use Notice .....                         | 2  |
| Educational notice.....                                  | 2  |
| Ethical and authorized use .....                         | 2  |
| Preface.....                                             | 3  |
| How to Use This Manual .....                             | 4  |
| Table of Contents .....                                  | 4  |
| 1. NIST CSF 2.0 Foundations.....                         | 9  |
| 1.1 What CSF 2.0 is.....                                 | 9  |
| 1.2 What changed from CSF 1.1 .....                      | 9  |
| 1.3 What CSF 2.0 is not .....                            | 9  |
| 2. Core, Profiles, Tiers, and Supporting Resources ..... | 11 |
| 3. Practical Implementation Roadmap .....                | 12 |
| 4. GOVERN Function .....                                 | 13 |
| Organizational Context (GV.OC) .....                     | 13 |
| Risk Management Strategy (GV.RM).....                    | 13 |
| Roles, Responsibilities, and Authorities (GV.RR) .....   | 14 |
| Policy (GV.PO) .....                                     | 14 |
| Oversight (GV.OV).....                                   | 14 |
| Cybersecurity Supply Chain Risk Management (GV.SC) ..... | 15 |
| 5. IDENTIFY Function.....                                | 16 |

|                                                                      |    |
|----------------------------------------------------------------------|----|
| Asset Management (ID.AM) .....                                       | 16 |
| Risk Assessment (ID.RA) .....                                        | 16 |
| Improvement (ID.IM) .....                                            | 17 |
| 6. PROTECT Function .....                                            | 18 |
| Identity Management, Authentication, and Access Control (PR.AA)..... | 18 |
| Awareness and Training (PR.AT).....                                  | 18 |
| Data Security (PR.DS) .....                                          | 18 |
| Platform Security (PR.PS) .....                                      | 19 |
| Technology Infrastructure Resilience (PR.IR) .....                   | 19 |
| 7. DETECT Function.....                                              | 21 |
| Continuous Monitoring (DE.CM) .....                                  | 21 |
| Adverse Event Analysis (DE.AE) .....                                 | 21 |
| 8. RESPOND Function .....                                            | 23 |
| Incident Management (RS.MA) .....                                    | 23 |
| Incident Analysis (RS.AN) .....                                      | 23 |
| Incident Response Reporting and Communication (RS.CO) .....          | 24 |
| Incident Mitigation (RS.MI) .....                                    | 24 |
| 9. RECOVER Function.....                                             | 25 |
| Incident Recovery Plan Execution (RC.RP) .....                       | 25 |
| Incident Recovery Communication (RC.CO) .....                        | 25 |
| 10. Organizational Profiles .....                                    | 26 |
| 10.1 Profile scope statement.....                                    | 26 |
| 10.2 Outcome status .....                                            | 26 |
| 10.3 Gap prioritization.....                                         | 27 |
| 11. CSF Tiers .....                                                  | 28 |
| 12. Enterprise Risk, Risk Appetite, and Communication .....          | 29 |
| 12.1 Executive risk statement.....                                   | 29 |
| 12.2 Board-level questions.....                                      | 29 |
| 13. Cybersecurity Supply Chain Risk .....                            | 30 |
| 14. Metrics, Evidence, and Reporting .....                           | 31 |
| 14.1 Evidence quality .....                                          | 31 |
| 15. Compliance Verification and Control Testing .....                | 32 |
| 15.1 Practical verification tests .....                              | 32 |
| 15.2 Conclusion language.....                                        | 33 |

|                                         |    |
|-----------------------------------------|----|
| 16. Open-Source Tools for CSF Work..... | 34 |
| 16.1 Tool validation checklist .....    | 34 |
| 16.2 CISO Assistant .....               | 35 |
| Quick start .....                       | 35 |
| Evidence and limitation .....           | 35 |
| 16.3 Wazuh .....                        | 35 |
| Quick start .....                       | 35 |
| Evidence and limitation .....           | 35 |
| 16.4 osquery.....                       | 35 |
| Quick start .....                       | 35 |
| Evidence and limitation .....           | 36 |
| 16.5 OpenSCAP .....                     | 36 |
| Quick start .....                       | 36 |
| Evidence and limitation .....           | 36 |
| 16.6 Greenbone Community Edition .....  | 36 |
| Quick start .....                       | 36 |
| Evidence and limitation .....           | 36 |
| 16.7 Trivy .....                        | 36 |
| Quick start .....                       | 36 |
| Evidence and limitation .....           | 37 |
| 16.8 OWASP ZAP .....                    | 37 |
| Quick start .....                       | 37 |
| Evidence and limitation .....           | 37 |
| 16.9 Keycloak .....                     | 37 |
| Quick start .....                       | 37 |
| Evidence and limitation .....           | 37 |
| 16.10 DefectDojo.....                   | 37 |
| Quick start .....                       | 37 |
| Evidence and limitation .....           | 37 |
| 16.11 Velociraptor .....                | 38 |
| Quick start .....                       | 38 |
| Evidence and limitation .....           | 38 |
| 16.12 Open Policy Agent .....           | 38 |
| Quick start .....                       | 38 |

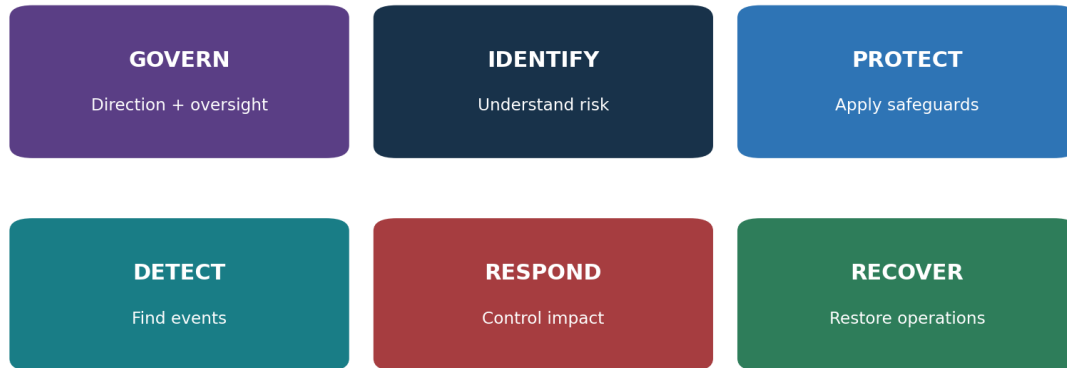
|                                              |    |
|----------------------------------------------|----|
| Evidence and limitation .....                | 38 |
| 16.13 OpenSearch .....                       | 38 |
| Quick start .....                            | 38 |
| Evidence and limitation .....                | 38 |
| 16.14 Official NIST tools .....              | 38 |
| 17. Manager's CSF Playbook.....              | 40 |
| 17.1 Monthly questions.....                  | 40 |
| 17.2 Dashboard .....                         | 40 |
| 17.3 Common mistakes .....                   | 40 |
| 18. From Beginner to Junior Analyst.....     | 41 |
| 18.1 Entry-level roles .....                 | 41 |
| 18.2 Work a junior analyst may perform ..... | 41 |
| 18.3 Portfolio proof .....                   | 42 |
| 19. Fictional Laboratory and Portfolio.....  | 43 |
| Project 1 — Scope and context .....          | 43 |
| Project 2 — Asset and data map .....         | 43 |
| Project 3 — Risk.....                        | 43 |
| Project 4 — Profiles.....                    | 43 |
| Project 5 — Controls and tests .....         | 43 |
| Project 6 — Incident.....                    | 43 |
| Project 7 — Tools .....                      | 43 |
| Project 8 — Executive report.....            | 43 |
| 20. Thirty-Day Learning Plan.....            | 44 |
| 20.1 Daily habit.....                        | 44 |
| 21. Interview Preparation .....              | 45 |
| What is NIST CSF 2.0? .....                  | 45 |
| What are the six Functions? .....            | 45 |
| Why was Govern added? .....                  | 45 |
| What is a Current Profile?.....              | 45 |
| What is a Target Profile?.....               | 45 |
| What are Tiers?.....                         | 45 |
| Does CSF certify compliance?.....            | 45 |
| How do you verify an outcome? .....          | 45 |
| How should tools be used? .....              | 45 |

|                                                |    |
|------------------------------------------------|----|
| How do you prioritize gaps? .....              | 46 |
| 22. Templates and Checklists .....             | 47 |
| 22.1 Profile record .....                      | 47 |
| 22.2 Risk register .....                       | 47 |
| 22.3 Control test sheet.....                   | 47 |
| 22.4 Supplier review.....                      | 47 |
| 22.5 Manager readiness checklist.....          | 48 |
| 23. Glossary and Subject Index .....           | 49 |
| 23.1 Subject index .....                       | 49 |
| 24. Official References and Further Study..... | 50 |



# 1. NIST CSF 2.0 Foundations

*What the framework is, what changed, and what it does not claim.*



**The Functions work together continuously; their order does not determine importance**

*Figure 1. The six NIST CSF 2.0 Functions*

## 1.1 What CSF 2.0 is

NIST published CSF 2.0 on February 26, 2024. It is designed for organizations of every size, sector, and level of technical sophistication. Its outcomes are country-, sector-, and technology-neutral. Organizations may adopt it voluntarily or because a policy, contract, regulator, customer, or internal standard calls for it.

## 1.2 What changed from CSF 1.1

- ✓ GOVERN became a sixth Function, placing leadership, policy, enterprise risk, and accountability at the center.
- ✓ Supply-chain cybersecurity received greater emphasis.
- ✓ The language was broadened beyond critical infrastructure so the framework clearly serves all organizations.
- ✓ Profiles, Tiers, Implementation Examples, Informative References, and Quick-Start Guides form a larger CSF portfolio.
- ✓ Some Subcategory numbers contain intentional gaps because CSF 1.1 content moved within CSF 2.0.

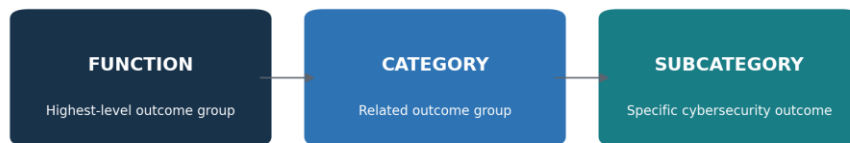
## 1.3 What CSF 2.0 is not

- ✓ It is not a law by itself.
- ✓ It is not a single control catalog or mandatory technology list.

- ✓ It does not provide a universal pass/fail score.
- ✓ NIST does not certify organizations, products, consultants, or assessors against the CSF.
- ✓ A high Tier is not automatically the right target for every scope.
- ✓ A mapping to a CSF outcome does not prove that the outcome is achieved.

## 2. Core, Profiles, Tiers, and Supporting Resources

*The pieces of CSF 2.0 and how they fit together.*



**Core outcomes describe what should be achieved—not a required product or single implementation method**

*Figure 2. CSF Core hierarchy*

| Component               | Purpose                                                                 | Practical use                                                     |
|-------------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------|
| Core                    | A hierarchy of six Functions, 22 Categories, and 106 Subcategories      | Describe desired cybersecurity outcomes                           |
| Organizational Profile  | Current and/or Target outcomes for a defined scope                      | Compare posture, prioritize gaps, plan work                       |
| Community Profile       | A shared outcome baseline for a sector, technology, threat, or use case | Use as input to an organizational Target Profile                  |
| Tiers                   | Context for the rigor of governance and risk-management practices       | Characterize Current and Target Profile conditions                |
| Implementation Examples | Notional actions that may help achieve outcomes                         | Generate ideas; tailor and validate                               |
| Informative References  | Mappings to standards, guidance, regulations, and other sources         | Select more detailed practices and controls                       |
| Quick-Start Guides      | Short actionable guidance on specific CSF uses                          | Start Profiles, Tiers, ERM, supply-chain, and small-business work |

**Numbers that matter:** CSF 2.0 contains 6 Functions, 22 Categories, and 106 Subcategories. The Subcategories describe outcomes, not required products or identical implementations.

### 3. Practical Implementation Roadmap

*A repeatable way to move from framework language to funded improvement.*

- ✓ Name an executive sponsor and program owner.
- ✓ Define the Profile scope: enterprise, business unit, product, service, system, region, or supplier ecosystem.
- ✓ Gather mission, stakeholder, legal, contractual, risk, asset, threat, incident, audit, workforce, and supplier information.
- ✓ Select applicable CSF outcomes and create a Current Profile using reliable evidence.
- ✓ Define a risk-based Target Profile, considering Community Profiles and obligations.
- ✓ Analyze gaps, dependencies, cost, feasibility, and risk reduction.
- ✓ Create an approved action plan with owners, resources, milestones, measures, and interim protection.
- ✓ Implement controls and operating procedures.
- ✓ Test design and operating effectiveness with complete populations and representative samples.
- ✓ Report risk, decisions, exceptions, progress, and limitations.
- ✓ Update Profiles after material changes, incidents, exercises, reviews, or shifting risk.

**Start small without losing integrity:** A small organization can begin with a critical service or high-risk process. Keep the scope honest, record exclusions, and expand deliberately.

## 4. GOVERN Function

*A complete plain-language breakdown of every GOVERN Category and Subcategory.*

**Function purpose:** Set direction, expectations, accountability, policy, oversight, and supply-chain risk management.

### Organizational Context (GV.OC)

| Outcome  | Plain meaning                                                                                             | Manager or analyst verification                                                                            | Example evidence                                                      |
|----------|-----------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| GV.OC-01 | Connect cybersecurity decisions to the organization's mission.                                            | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | mission and stakeholder records, obligations register, dependency map |
| GV.OC-02 | Identify stakeholders and consider their cybersecurity expectations.                                      | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | mission and stakeholder records, obligations register, dependency map |
| GV.OC-03 | Identify and manage legal, regulatory, contractual, privacy, and civil-liberties obligations.             | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | mission and stakeholder records, obligations register, dependency map |
| GV.OC-04 | Understand and communicate the critical services others expect from the organization.                     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | mission and stakeholder records, obligations register, dependency map |
| GV.OC-05 | Understand and communicate the external outcomes, capabilities, and services the organization depends on. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | mission and stakeholder records, obligations register, dependency map |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Risk Management Strategy (GV.RM)

| Outcome  | Plain meaning                                                                         | Manager or analyst verification                                                                            | Example evidence                                                 |
|----------|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| GV.RM-01 | Agree on cybersecurity risk-management objectives with relevant stakeholders.         | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |
| GV.RM-02 | Establish, communicate, and maintain risk appetite and tolerance statements.          | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |
| GV.RM-03 | Integrate cybersecurity risk into enterprise risk-management processes.               | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |
| GV.RM-04 | Define and communicate acceptable risk-response options.                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |
| GV.RM-05 | Create communication paths for cyber risks, including supplier and third-party risks. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |

| Outcome  | Plain meaning                                                                           | Manager or analyst verification                                                                            | Example evidence                                                 |
|----------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| GV.RM-06 | Use a consistent method to calculate, document, categorize, and prioritize cyber risks. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |
| GV.RM-07 | Include beneficial opportunities and positive risk in cybersecurity discussions.        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | risk appetite, method, enterprise risk register, reporting paths |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Roles, Responsibilities, and Authorities (GV.RR)

| Outcome  | Plain meaning                                                                                        | Manager or analyst verification                                                                            | Example evidence                                  |
|----------|------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| GV.RR-01 | Leadership accepts accountability for cybersecurity risk and supports an ethical, improving culture. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | RACI, job descriptions, budget, workforce records |
| GV.RR-02 | Establish, communicate, understand, and enforce cyber roles, responsibilities, and authority.        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | RACI, job descriptions, budget, workforce records |
| GV.RR-03 | Allocate people, money, technology, and time in line with risk strategy and policy.                  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | RACI, job descriptions, budget, workforce records |
| GV.RR-04 | Include cybersecurity responsibilities in human-resources practices.                                 | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | RACI, job descriptions, budget, workforce records |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Policy (GV.PO)

| Outcome  | Plain meaning                                                                                        | Manager or analyst verification                                                                            | Example evidence                                                      |
|----------|------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| GV.PO-01 | Establish, communicate, and enforce cybersecurity policy based on context, strategy, and priorities. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | approved policy, acknowledgments, review history, enforcement records |
| GV.PO-02 | Review and update policy when requirements, threats, technology, or the mission change.              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | approved policy, acknowledgments, review history, enforcement records |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Oversight (GV.OV)

| Outcome  | Plain meaning                                              | Manager or analyst verification                                                                            | Example evidence                                        |
|----------|------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| GV.OV-01 | Review strategy outcomes and use them to adjust direction. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | dashboard, meeting minutes, decisions, strategy changes |

| Outcome  | Plain meaning                                                              | Manager or analyst verification                                                                            | Example evidence                                        |
|----------|----------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| GV.OV-02 | Adjust the risk strategy when requirements or risks are not fully covered. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | dashboard, meeting minutes, decisions, strategy changes |
| GV.OV-03 | Evaluate cybersecurity performance and determine needed changes.           | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | dashboard, meeting minutes, decisions, strategy changes |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Cybersecurity Supply Chain Risk Management (GV.SC)

| Outcome  | Plain meaning                                                                                 | Manager or analyst verification                                                                            | Example evidence                                                              |
|----------|-----------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| GV.SC-01 | Establish an agreed supply-chain risk program, strategy, objectives, policies, and processes. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-02 | Coordinate cybersecurity roles for suppliers, customers, partners, and internal owners.       | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-03 | Integrate supply-chain risk into cybersecurity, ERM, assessment, and improvement work.        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-04 | Know suppliers and prioritize them by criticality.                                            | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-05 | Put prioritized cybersecurity requirements into contracts and agreements.                     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-06 | Perform planning and due diligence before beginning third-party relationships.                | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-07 | Record, assess, respond to, and monitor supplier, product, service, and third-party risks.    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-08 | Include relevant third parties in incident planning, response, and recovery.                  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-09 | Monitor supply-chain security across the technology product and service life cycle.           | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |
| GV.SC-10 | Plan security activities for the end of a partnership or service agreement.                   | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | supplier inventory, tiering, due diligence, contracts, monitoring, exit proof |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## 5. IDENTIFY Function

*A complete plain-language breakdown of every IDENTIFY Category and Subcategory.*

**Function purpose:** Understand assets, dependencies, threats, vulnerabilities, risks, and improvement needs.

### Asset Management (ID.AM)

| Outcome  | Plain meaning                                                                        | Manager or analyst verification                                                                            | Example evidence                                                 |
|----------|--------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| ID.AM-01 | Maintain an inventory of managed hardware.                                           | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-02 | Maintain an inventory of managed software, services, and systems.                    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-03 | Maintain current diagrams of authorized network communication and data flows.        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-04 | Maintain an inventory of supplier-provided services.                                 | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-05 | Prioritize assets by classification, criticality, resources, and mission impact.     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-07 | Inventory designated data types and their metadata.                                  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |
| ID.AM-08 | Manage systems, hardware, software, services, and data throughout their life cycles. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | asset and data inventories, owners, diagrams, life-cycle records |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Risk Assessment (ID.RA)

| Outcome  | Plain meaning                                                    | Manager or analyst verification                                                                            | Example evidence                                                          |
|----------|------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| ID.RA-01 | Identify, validate, and record asset vulnerabilities.            | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-02 | Receive cyber threat intelligence from suitable sharing sources. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-03 | Identify and record internal and external threats.               | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |



| Outcome  | Plain meaning                                                                                    | Manager or analyst verification                                                                            | Example evidence                                                          |
|----------|--------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| ID.RA-04 | Estimate the likelihood and impact of threats exploiting vulnerabilities.                        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-05 | Use threats, vulnerabilities, likelihood, and impact to understand inherent risk and priorities. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-06 | Choose, prioritize, plan, track, and communicate risk responses.                                 | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-07 | Assess, record, approve, and track the risk effect of changes and exceptions.                    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-08 | Establish a process to receive, analyze, and respond to vulnerability disclosures.               | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-09 | Assess hardware and software authenticity and integrity before acquisition and use.              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |
| ID.RA-10 | Assess critical suppliers before acquisition.                                                    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | threat and vulnerability records, risk analysis, treatment and exceptions |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Improvement (ID.IM)

| Outcome  | Plain meaning                                                                                        | Manager or analyst verification                                                                            | Example evidence                                                 |
|----------|------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| ID.IM-01 | Identify improvements from evaluations.                                                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | assessment, exercise, lessons, corrective actions, updated plans |
| ID.IM-02 | Identify improvements from tests and exercises, including coordinated third-party exercises.         | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | assessment, exercise, lessons, corrective actions, updated plans |
| ID.IM-03 | Identify improvements while operating processes, procedures, and activities.                         | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | assessment, exercise, lessons, corrective actions, updated plans |
| ID.IM-04 | Establish, communicate, maintain, and improve incident-response and operational cybersecurity plans. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | assessment, exercise, lessons, corrective actions, updated plans |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## 6. PROTECT Function

*A complete plain-language breakdown of every PROTECT Category and Subcategory.*

**Function purpose:** Use safeguards that reduce the likelihood and impact of cybersecurity events.

### Identity Management, Authentication, and Access Control (PR.AA)

| Outcome  | Plain meaning                                                                           | Manager or analyst verification                                                                            | Example evidence                                                          |
|----------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| PR.AA-01 | Manage identities and credentials for authorized people, services, and hardware.        | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |
| PR.AA-02 | Proof identities and bind them to credentials according to the interaction's risk.      | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |
| PR.AA-03 | Authenticate users, services, and hardware.                                             | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |
| PR.AA-04 | Protect, transmit, and verify identity assertions.                                      | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |
| PR.AA-05 | Define, enforce, and review permissions using least privilege and separation of duties. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |
| PR.AA-06 | Manage, monitor, and enforce physical access according to risk.                         | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | identity inventory, access matrix, MFA settings, reviews, removal tickets |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Awareness and Training (PR.AT)

| Outcome  | Plain meaning                                                                                | Manager or analyst verification                                                                            | Example evidence                                                |
|----------|----------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| PR.AT-01 | Give personnel the knowledge and skills to perform ordinary work with cyber risk in mind.    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | role-based curriculum, roster, completion, exercises, follow-up |
| PR.AT-02 | Give people in specialized roles the cybersecurity knowledge and skills those roles require. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | role-based curriculum, roster, completion, exercises, follow-up |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Data Security (PR.DS)

| Outcome | Plain meaning | Manager or analyst verification | Example evidence |
|---------|---------------|---------------------------------|------------------|
|---------|---------------|---------------------------------|------------------|

| Outcome  | Plain meaning                                                             | Manager or analyst verification                                                                            | Example evidence                                                           |
|----------|---------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| PR.DS-01 | Protect data at rest for confidentiality, integrity, and availability.    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | classification, encryption settings, DLP records, backup and restore tests |
| PR.DS-02 | Protect data in transit for confidentiality, integrity, and availability. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | classification, encryption settings, DLP records, backup and restore tests |
| PR.DS-10 | Protect data in use for confidentiality, integrity, and availability.     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | classification, encryption settings, DLP records, backup and restore tests |
| PR.DS-11 | Create, protect, maintain, and test backups.                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | classification, encryption settings, DLP records, backup and restore tests |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Platform Security (PR.PS)

| Outcome  | Plain meaning                                                                          | Manager or analyst verification                                                                            | Example evidence                                                           |
|----------|----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| PR.PS-01 | Establish and apply configuration-management practices.                                | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |
| PR.PS-02 | Maintain, replace, and remove software according to risk.                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |
| PR.PS-03 | Maintain, replace, and remove hardware according to risk.                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | Baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |
| PR.PS-04 | Generate logs and make them available for continuous monitoring.                       | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | Baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |
| PR.PS-05 | Prevent installation and execution of unauthorized software.                           | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |
| PR.PS-06 | Integrate and monitor secure software development practices throughout the life cycle. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | baselines, patch and EOL records, logs, allowlisting, secure-SDLC evidence |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Technology Infrastructure Resilience (PR.IR)

| Outcome  | Plain meaning                                                               | Manager or analyst verification                                                                            | Example evidence                                                                  |
|----------|-----------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| PR.IR-01 | Protect networks and environments from unauthorized logical access and use. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | architecture, segmentation, environmental controls, resilience and capacity tests |
| PR.IR-02 | Protect technology assets from environmental threats.                       | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | architecture, segmentation, environmental controls, resilience and capacity tests |

| Outcome  | Plain meaning                                                                         | Manager or analyst verification                                                                            | Example evidence                                                                  |
|----------|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| PR.IR-03 | Implement mechanisms that meet resilience needs during normal and adverse conditions. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | architecture, segmentation, environmental controls, resilience and capacity tests |
| PR.IR-04 | Maintain enough resource capacity to support availability.                            | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | architecture, segmentation, environmental controls, resilience and capacity tests |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## 7. DETECT Function

*A complete plain-language breakdown of every DETECT Category and Subcategory.*

**Function purpose:** Monitor and analyze events so potential attacks and compromises are found.

### Continuous Monitoring (DE.CM)

| Outcome  | Plain meaning                                                                  | Manager or analyst verification                                                                            | Example evidence                                                           |
|----------|--------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| DE.CM-01 | Monitor networks and network services for potentially adverse events.          | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | coverage inventory, telemetry, alerts, review records, provider monitoring |
| DE.CM-02 | Monitor the physical environment for potentially adverse events.               | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | coverage inventory, telemetry, alerts, review records, provider monitoring |
| DE.CM-03 | Monitor personnel activity and technology use for potentially adverse events.  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | coverage inventory, telemetry, alerts, review records, provider monitoring |
| DE.CM-06 | Monitor external service-provider activities and services for adverse events.  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | coverage inventory, telemetry, alerts, review records, provider monitoring |
| DE.CM-09 | Monitor hardware, software, runtime environments, and data for adverse events. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | coverage inventory, telemetry, alerts, review records, provider monitoring |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Adverse Event Analysis (DE.AE)

| Outcome  | Plain meaning                                                      | Manager or analyst verification                                                                            | Example evidence                                                        |
|----------|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| DE.AE-02 | Analyze potentially adverse events to understand related activity. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |
| DE.AE-03 | Correlate information from multiple sources.                       | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |
| DE.AE-04 | Estimate the scope and impact of adverse events.                   | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |
| DE.AE-06 | Provide adverse-event information to authorized people and tools.  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |
| DE.AE-07 | Use threat intelligence and context in event analysis.             | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |
| DE.AE-08 | Declare incidents when events meet defined criteria.               | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | correlation rules, enriched alerts, impact analysis, declaration record |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## 8. RESPOND Function

*A complete plain-language breakdown of every RESPOND Category and Subcategory.*

**Function purpose:** Manage, analyze, communicate, contain, and eradicate declared incidents.

### Incident Management (RS.MA)

| Outcome  | Plain meaning                                                                         | Manager or analyst verification                                                                            | Example evidence                                                        |
|----------|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| RS.MA-01 | Execute the response plan with relevant third parties after an incident are declared. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | incident plan, tickets, triage, priority, escalation, recovery decision |
| RS.MA-02 | Triage and validate incident reports.                                                 | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | incident plan, tickets, triage, priority, escalation, recovery decision |
| RS.MA-03 | Categorize and prioritize incidents.                                                  | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | incident plan, tickets, triage, priority, escalation, recovery decision |
| RS.MA-04 | Escalate or elevate incidents when required.                                          | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | incident plan, tickets, triage, priority, escalation, recovery decision |
| RS.MA-05 | Apply criteria for beginning recovery.                                                | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | incident plan, tickets, triage, priority, escalation, recovery decision |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Incident Analysis (RS.AN)

| Outcome  | Plain meaning                                                                 | Manager or analyst verification                                                                            | Example evidence                                                    |
|----------|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| RS.AN-03 | Determine what occurred and identify root cause.                              | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | timeline, forensic notes, evidence log, hashes, root-cause analysis |
| RS.AN-06 | Record investigative actions and preserve record integrity and provenance.    | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | timeline, forensic notes, evidence log, hashes, root-cause analysis |
| RS.AN-07 | Collect incident data and metadata while preserving integrity and provenance. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | timeline, forensic notes, evidence log, hashes, root-cause analysis |
| RS.AN-08 | Estimate and validate incident magnitude.                                     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | timeline, forensic notes, evidence log, hashes, root-cause analysis |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Incident Response Reporting and Communication (RS.CO)

| Outcome  | Plain meaning                                       | Manager or analyst verification                                                                            | Example evidence                                           |
|----------|-----------------------------------------------------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| RS.CO-02 | Notify required internal and external stakeholders. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | notification matrix, messages, approvals, delivery records |
| RS.CO-03 | Share information with designated stakeholders.     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | notification matrix, messages, approvals, delivery records |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## Incident Mitigation (RS.MI)

| Outcome  | Plain meaning        | Manager or analyst verification                                                                            | Example evidence                                                        |
|----------|----------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| RS.MI-01 | Contain incidents.   | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | containment and eradication actions, validation, residual-risk decision |
| RS.MI-02 | Eradicate incidents. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | containment and eradication actions, validation, residual-risk decision |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*



## 9. RECOVER Function

*A complete plain-language breakdown of every RECOVER Category and Subcategory.*

**Function purpose:** Restore assets and operations and communicate recovery progress.

### Incident Recovery Plan Execution (RC.RP)

| Outcome  | Plain meaning                                                                     | Manager or analyst verification                                                                            | Example evidence                                                           |
|----------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| RC.RP-01 | Execute recovery activities when the incident process initiates recovery.         | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |
| RC.RP-02 | Select, scope, prioritize, and perform recovery actions.                          | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |
| RC.RP-03 | Verify backup and restoration-asset integrity before restoration.                 | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |
| RC.RP-04 | Use mission needs and cyber risk to establish post-incident operating conditions. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |
| RC.RP-05 | Verify restored assets, restore service, and confirm normal operating status.     | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |
| RC.RP-06 | Declare recovery complete using criteria and finish incident documentation.       | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | recovery plan, restore logs, integrity checks, service validation, closure |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

### Incident Recovery Communication (RC.CO)

| Outcome  | Plain meaning                                                                     | Manager or analyst verification                                                                            | Example evidence                                              |
|----------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| RC.CO-03 | Communicate recovery progress and restored capability to designated stakeholders. | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | stakeholder updates, approved public messages, delivery proof |
| RC.CO-04 | Issue public recovery updates through approved methods and messaging.             | Confirm ownership, scope, implementation, review, exceptions, corrective action, and repeatable operation. | stakeholder updates, approved public messages, delivery proof |

*Important: CSF outcomes are not a checklist of required technologies. Select implementation methods and controls according to risk, mission, obligations, resources, and the scoped Target Profile.*

## 10. Organizational Profiles

*How to describe current posture, set a target, and build a prioritized action plan.*



**Profiles turn CSF outcomes into a risk-based improvement roadmap**

*Figure 3. Current Profile to action plan*

### 10.1 Profile scope statement

- ✓ Business or mission purpose
- ✓ Systems, services, data, facilities, people, suppliers, and locations included
- ✓ Time period and evidence date
- ✓ Stakeholders and decision authority
- ✓ Legal, contractual, policy, and Community Profile inputs
- ✓ Assumptions, exclusions, dependencies, and limitations

### 10.2 Outcome status

| Status             | Meaning                                                     | Required support                                                            |
|--------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------|
| Achieved           | The scoped outcome is implemented and operating as intended | Owner, complete population, design, operating evidence, test and conclusion |
| Partially achieved | Some scope or operation is missing or inconsistent          | Exact gap, affected risk, interim action, owner and date                    |
| Not achieved       | The outcome is applicable but not operating                 | Risk decision, treatment, resources, schedule                               |
| Not applicable     | The outcome does not apply to this defined scope            | Documented rationale and approval                                           |
| Not assessed       | Evidence is insufficient for a conclusion                   | Evidence request, owner and deadline                                        |

### 10.3 Gap prioritization

Prioritize gaps using mission impact, threat likelihood, asset criticality, legal and contractual obligations, exposure, dependencies, safety, privacy, current controls, time to exploit, remediation effort, and available resources. Do not rank gaps only by a scanner's severity label.

## 11. CSF Tiers

*Using Partial, Risk Informed, Repeatable, and Adaptive without turning them into a score.*



**Tiers describe rigor and context; they are not maturity scores or a universal race to Tier 4**

*Figure 4. CSF Tiers*

| Tier                   | Plain meaning                                                                                                      | Useful evidence                                                                                       |
|------------------------|--------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Tier 1 — Partial       | Practices are largely ad hoc, irregular, and inconsistently informed by objectives or threats.                     | Examples of case-by-case decisions and missing organization-wide processes                            |
| Tier 2 — Risk Informed | Management approves risk practices, but they are not consistently established across the organization.             | Approved practices, local implementation, partial risk and supplier awareness                         |
| Tier 3 — Repeatable    | Policies and repeatable practices are defined, implemented, reviewed, and updated across the organization.         | Approved policy, consistent execution, skilled roles, regular information sharing and supplier action |
| Tier 4 — Adaptive      | Risk management is part of culture and adapts using lessons, predictive information, and near-real-time awareness. | Integrated ERM decisions, adaptive controls, continuous improvement and timely supplier-risk action   |

- Choose Tiers for a defined Profile scope, not as a vague enterprise label.
- Use risk, mission, obligations, cost, and benefit to choose the Target Tier.
- Do not average Tier numbers into a misleading score.
- Document evidence and differences across Functions.
- Reassess when risk, mission, suppliers, or technology materially changes.

## 12. Enterprise Risk, Risk Appetite, and Communication

*Connecting cybersecurity with executive and board decisions.*

| Concept        | Plain meaning                                                                     | Example                                                                           |
|----------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Risk appetite  | The broad amount and type of risk the organization is willing to pursue or retain | Very low appetite for interruption of emergency services                          |
| Risk tolerance | Specific acceptable variation around objectives                                   | No more than four hours of outage for a defined critical service                  |
| Inherent risk  | Risk before considering controls                                                  | Internet-facing service with valuable data and active threats                     |
| Residual risk  | Risk remaining after controls                                                     | Remaining outage or breach risk after MFA, segmentation, monitoring, and recovery |
| Risk response  | Accept, avoid, mitigate, transfer/share, or pursue opportunity                    | Retire unsupported software, reduce exposure, insure a residual portion           |
| Positive risk  | Opportunity that may improve objectives                                           | Secure automation that reduces error and improves detection speed                 |

### 12.1 Executive risk statement

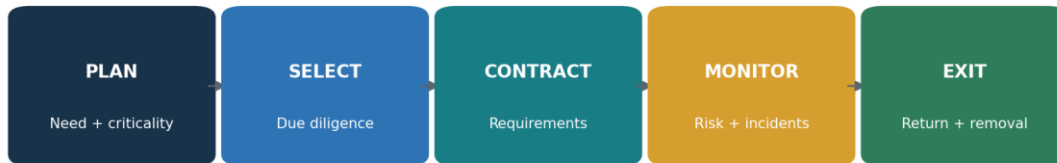
**Pattern:** Because [threat] could exploit [vulnerability] affecting [asset or objective], the organization may experience [business impact]. Existing controls [summary] leave [residual exposure]. Management should [response] by [date], owned by [role], and monitor [measure].

### 12.2 Board-level questions

- Which mission objectives and critical services face the greatest cyber risk?
- What risk exceeds appetite or tolerance?
- Which decisions require funding or risk acceptance?
- How reliable is the evidence behind reported status?
- Where are supplier concentrations and single points of failure?
- What did incidents, exercises, audits, and near misses teach us?
- Are recovery capabilities proven for the most important services?

## 13. Cybersecurity Supply Chain Risk

*Managing suppliers, products, services, and dependencies across the life cycle.*



**Supply-chain cybersecurity continues through the full relationship and technology life cycle**

*Figure 5. Supply-chain cybersecurity life cycle*

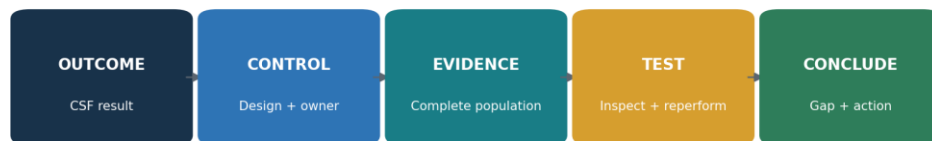
1. Inventory suppliers, subcontractors, products, services, data flows, access, locations, and dependencies.
2. Tier relationships by criticality, sensitivity, access, substitutability, concentration, safety, and operational impact.
3. Perform proportionate due diligence before purchase or renewal.
4. Place measurable cybersecurity, incident, notification, evidence, subcontractor, resilience, return, and destruction duties in agreements.
5. Monitor changes, findings, incidents, financial health, service performance, and material fourth-party dependencies.
6. Include critical third parties in exercises, response, recovery, and communication.
7. At exit, remove access, retrieve assets, return or destroy data, transfer knowledge, preserve required records, and validate completion.

**Contract warning:** A questionnaire or contract clause does not prove that a supplier's controls operate. Combine contractual rights with risk-based evidence, monitoring, incident information, and corrective-action follow-up.

## 14. Metrics, Evidence, and Reporting

*Measures that support decisions instead of producing decorative dashboards.*

| Measure type             | Question answered                          | Example                                                                                     |
|--------------------------|--------------------------------------------|---------------------------------------------------------------------------------------------|
| Implementation measure   | Was the safeguard deployed?                | Percentage of in-scope privileged accounts using phishing-resistant MFA                     |
| Operating measure        | Is it functioning consistently?            | Percentage of terminated accounts disabled within the approved time                         |
| Risk indicator           | Is exposure increasing?                    | Critical vulnerabilities past risk-based deadline on internet-facing assets                 |
| Outcome measure          | Is the desired result occurring?           | Reduction in unauthorized access events for the scoped service                              |
| Resilience measure       | Can the organization continue and recover? | Percentage of critical-service restores meeting recovery objectives                         |
| Evidence-quality measure | Can reported status be trusted?            | Percentage of outcome conclusions supported by complete populations and independent testing |



**A framework mapping becomes defensible only when implementation and operating evidence are tested**

*Figure 6. Outcome-to-evidence chain*

### 14.1 Evidence quality

| Quality | Example                                                                       | Analyst response                                                              |
|---------|-------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| Weak    | Verbal statement, undated screenshot, partial export, unsupported summary     | Request source, date, scope, population, owner, reviewer, and system identity |
| Useful  | Dated system report tied to the right scope and period                        | Confirm configuration, completeness, access, interpretation, and exceptions   |
| Strong  | System data plus independent review, decisions, corrective action, and retest | Trace the full chain and state limitations                                    |

## 15. Compliance Verification and Control Testing

*How to determine whether a scoped CSF outcome is actually achieved.*

**Important distinction:** CSF alignment is not automatically legal compliance, certification, or an audit opinion. Test the actual obligations and controls that apply to the organization, then use CSF outcomes to organize and communicate results.

1. Define the scoped CSF outcome, risk, control, owner, systems, locations, population, period, frequency, and expected evidence.
2. Evaluate control design: would the control, if performed as described, reasonably achieve the intended outcome?
3. Obtain the complete population and test its completeness and accuracy against an independent source.
4. Choose a risk-based sample covering relevant dates, systems, owners, locations, unusual items, and failures.
5. Inspect evidence and, where practical, reperform or independently confirm the control result.
6. Record exceptions with exact criteria, facts, duration, affected assets, cause, likelihood, impact, and existing protection.
7. Assign corrective action, interim protection, owner, resources, due date, and escalation.
8. Retest the correction across the affected population and write a clear conclusion with limitations.

### 15.1 Practical verification tests

| Control area             | Population and sample                                                                                         | Test procedure                                                                                              | Evidence                                                              |
|--------------------------|---------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| Asset inventory          | All in-scope assets; sample critical, new, cloud, remote, supplier-managed, and retired items                 | Reconcile inventory with identity, network, cloud, procurement, vulnerability, and endpoint sources         | Exports, reconciliation, ownership, gaps, correction and retest       |
| Access lifecycle         | All joiners, movers, leavers, service and privileged accounts                                                 | Compare approvals and role need with provisioning, review, change, and removal timestamps                   | HR/IAM populations, approvals, reviews, tickets, logs, exceptions     |
| Vulnerability management | All assets and findings; sample critical, high, aged, accepted, and closed items                              | Validate coverage and credentials, confirm findings, deadlines, correction, exception, and rescan           | Inventory, scan setup, report, tickets, approvals, rescan             |
| Logging and detection    | All required log sources, alerts, reviews, and incidents                                                      | Test source coverage, time, rule, alert generation, review, escalation, and retention                       | Source list, configuration, alert, ticket, review and closure         |
| Backup and recovery      | All backup jobs and required tests; sample success, failure, and critical services                            | Inspect protection, failure response, restore, integrity, recovery objectives, and lessons                  | Jobs, alerts, restore output, exercise, correction, retest            |
| Supplier oversight       | All suppliers; sample critical, new, changed, incident-involved, and exited relationships                     | Test tiering, due diligence, contract, monitoring, incident duties, corrective action, and exit             | Inventory, assessment, agreement, findings, monitoring, removal proof |
| Incident response        | Complete event and incident population reconciled to alert, help-desk, privacy, legal, and operations sources | Test declaration, triage, analysis, evidence, notification, containment, eradication, recovery, and lessons | Timeline, tickets, evidence log, messages, recovery and improvement   |
| Secure development       | All in-scope repositories, releases, dependencies, exceptions, and findings                                   | Test requirements, review, scanning, secrets, dependencies, approval, deployment, correction, and retest    | Pipeline logs, review, scan, ticket, release and validation           |

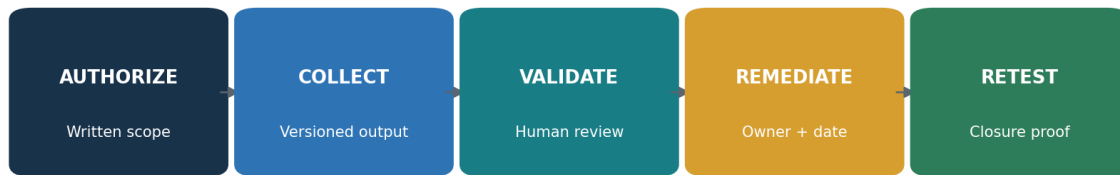


## 15.2 Conclusion language

**Example:** For the defined service and review period, the control was suitably designed and operated for 37 of 40 sampled events. Three late access removals exceeded the approved tolerance. Management assigned corrective action, added automated escalation, and retesting confirmed timely removal for the subsequent complete population. The conclusion does not cover systems excluded from the stated scope.

## 16. Open-Source Tools for CSF Work

*Official links, safe quick starts, CSF support, evidence, and limitations.*



**A tool report is input—not proof that a CSF outcome is achieved**

*Figure 7. From tool output to evidence*

| Tool                        | Purpose                                                     | Possible CSF support |
|-----------------------------|-------------------------------------------------------------|----------------------|
| CISO Assistant              | GRC, Profiles, risks, controls, evidence                    | GV, ID, reporting    |
| Wazuh                       | SIEM, endpoint monitoring, integrity                        | DE.CM, DE.AE, RS.MA  |
| osquery                     | Endpoint inventory and query evidence                       | ID.AM, PR.PS, PR.AA  |
| OpenSCAP                    | Linux configuration assessment                              | PR.PS, ID.IM         |
| Greenbone Community Edition | Vulnerability assessment                                    | ID.RA, ID.IM         |
| Trivy                       | Code, image, dependency, secret, and configuration scanning | ID.RA, PR.PS         |
| OWASP ZAP                   | Authorized web-application assessment                       | ID.RA, ID.IM         |
| Keycloak                    | Identity, roles, authentication, and MFA                    | PR.AA                |
| DefectDojo                  | Finding intake and remediation tracking                     | ID.RA, ID.IM, GV.OV  |
| Velociraptor                | Endpoint visibility and incident response                   | DE.CM, RS.AN         |
| Open Policy Agent           | Policy as code                                              | GV.PO, PR.AA, PR.PS  |
| OpenSearch                  | Search, analytics, dashboards, and security monitoring      | DE.CM, DE.AE, GV.OV  |

### 16.1 Tool validation checklist

- ✓ Approve purpose, owner, scope, data, systems, hosting, support access, and retention.
- ✓ Verify the official source, version, dependencies, integrity, update method, and secure configuration.
- ✓ Test a known condition the tool should detect or block.
- ✓ Test a known allowed condition to identify unnecessary failures.

- ✓ Compare tool coverage with an independent asset, agent, repository, or identity population.
- ✓ Restrict administration, protect credentials and reports, log changes, and test tool backup or recovery.
- ✓ Define human validation, escalation, exception, correction, and retest.
- ✓ Revalidate after material upgrades, integration changes, configuration changes, or failures.

## 16.2 CISO Assistant

GRC, Profiles, risks, controls, evidence. Possible CSF support: GV, ID, reporting.

**Official documentation:** [Open the official CISO Assistant guide](#)

### Quick start

Create a fictional organization, select five CSF outcomes, assign owners, attach sanitized evidence, record a gap, and build an action plan.

### Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.3 Wazuh

SIEM, endpoint monitoring, integrity. Possible CSF support: DE.CM, DE.AE, RS.MA.

**Official documentation:** [Open the official Wazuh guide](#)

### Quick start

Connect one authorized lab endpoint, create a harmless event, review the alert, document the decision, and retain the event and ticket.

### Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.4 osquery

Endpoint inventory and query evidence. Possible CSF support: ID.AM, PR.PS, PR.AA.

**Official documentation:** [Open the official osquery guide](#)

### Quick start

Query users, software, services, encryption, or processes on a lab endpoint; record query, host, time, output, and review.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.5 OpenSCAP

Linux configuration assessment. Possible CSF support: PR.PS, ID.IM.

**Official documentation:** [Open the official OpenSCAP guide](#)

### Quick start

Assess an authorized Linux lab against a suitable profile, correct one approved setting, and compare the before and after reports.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.6 Greenbone Community Edition

Vulnerability assessment. Possible CSF support: ID.RA, ID.IM.

**Official documentation:** [Open the official Greenbone Community Edition guide](#)

### Quick start

Scan only an approved lab target, validate one finding, correct it, rescan, and document scope and limitations.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.7 Trivy

Code, image, dependency, secret, and configuration scanning. Possible CSF support: ID.RA, PR.PS.

**Official documentation:** [Open the official Trivy guide](#)

### Quick start

Scan a pinned lab image or test repository, protect the report, validate one result, correct it, and scan again.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.8 OWASP ZAP

Authorized web-application assessment. Possible CSF support: ID.RA, ID.IM.

**Official documentation:** [Open the official OWASP ZAP guide](#)

### Quick start

Proxy a local training application, begin with passive analysis, validate one finding, and retain approved scope and results.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.9 Keycloak

Identity, roles, authentication, and MFA. Possible CSF support: PR.AA.

**Official documentation:** [Open the official Keycloak guide](#)

### Quick start

Create a lab realm, users, roles, and MFA; test least privilege, failed access, and removal; export sanitized configuration evidence.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.10 DefectDojo

Finding intake and remediation tracking. Possible CSF support: ID.RA, ID.IM, GV.OV.

**Official documentation:** [Open the official DefectDojo guide](#)

### Quick start

Import a lab report, validate and assign one finding, record correction, retest it, and close it with proof.

## Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.11 Velociraptor

Endpoint visibility and incident response. Possible CSF support: DE.CM, RS.AN.

**Official documentation:** [Open the official Velociraptor guide](#)

### Quick start

Use an isolated lab client, collect one harmless approved artifact, and record purpose, scope, collection, review, and preservation.

### Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.12 Open Policy Agent

Policy as code. Possible CSF support: GV.PO, PR.AA, PR.PS.

**Official documentation:** [Open the official Open Policy Agent guide](#)

### Quick start

Write a lab rule requiring an owner, classification, and approved environment; test allowed and denied inputs.

### Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.13 OpenSearch

Search, analytics, dashboards, and security monitoring. Possible CSF support: DE.CM, DE.AE, GV.OV.

**Official documentation:** [Open the official OpenSearch guide](#)

### Quick start

Load synthetic security events, build one search and dashboard, document data coverage, access, retention, review, and limitations.

### Evidence and limitation

Retain authorization, scope, target population, tool and content version, configuration, raw result, reviewer, decision, corrective action, exception, and retest. The tool supports selected work; it cannot certify CSF alignment, determine complete scope, or replace qualified human judgment.

## 16.14 Official NIST tools

**CSF 2.0 Reference Tool:** [Explore and export the official CSF Core](#)

**Organizational Profiles:** [Open NIST Profile guidance and templates](#)

## 17. Manager's CSF Playbook

*Questions, governance routines, dashboards, and decisions managers should control.*

### 17.1 Monthly questions

- What changed in mission, systems, data, threats, obligations, suppliers, or risk appetite?
- Which risks exceed tolerance and who has authority to decide?
- Are Current Profile conclusions supported by reliable evidence?
- Which action plans are late, blocked, underfunded, or dependent on others?
- Are critical suppliers monitored and included in incident and recovery work?
- Did control failures, incidents, exercises, tests, and near misses lead to improvement?
- Can critical services recover within approved objectives?
- What limitations should leadership understand before relying on the dashboard?

### 17.2 Dashboard

| Area        | Management question                                                          | Status               |
|-------------|------------------------------------------------------------------------------|----------------------|
| Governance  | Are strategy, policy, roles, resources, and oversight aligned to risk?       | Green / Yellow / Red |
| Profile     | Is scope current and is the Target Profile approved?                         | Green / Yellow / Red |
| Risk        | Which residual risks exceed tolerance?                                       | Green / Yellow / Red |
| Assets      | Are critical assets, data, flows, and suppliers known?                       | Green / Yellow / Red |
| Protection  | Are identity, data, platform, training, and resilience safeguards operating? | Green / Yellow / Red |
| Detection   | Is monitoring complete, reviewed, and connected to incident criteria?        | Green / Yellow / Red |
| Response    | Are incidents triaged, analyzed, communicated, contained, and eradicated?    | Green / Yellow / Red |
| Recovery    | Are restoration integrity and critical-service objectives proven?            | Green / Yellow / Red |
| Improvement | Are findings corrected and independently retested?                           | Green / Yellow / Red |

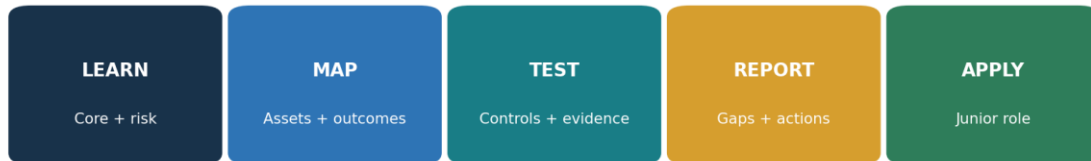
### 17.3 Common mistakes

- Treating CSF as an IT checklist instead of enterprise risk work.
- Beginning with tools instead of mission, scope, risk, and outcomes.
- Marking outcomes achieved from policy text alone.
- Using a single score that hides critical weaknesses and scope differences.
- Calling Tiers maturity levels without understanding NIST's intended context.
- Copying a Target Profile without tailoring it to organizational risk.
- Ignoring suppliers, cloud services, OT, data, people, facilities, and dependencies.
- Closing findings without retesting.
- Describing CSF alignment as legal compliance or NIST certification.



## 18. From Beginner to Junior Analyst

*A safe and honest path into GRC, risk, compliance, and cybersecurity analysis.*



**A strong portfolio shows honest scope, reliable evidence, clear writing, and safe practice**

*Figure 8. Junior analyst pathway*

### 18.1 Entry-level roles

Junior GRC Analyst  
 Cybersecurity Risk Analyst  
 Compliance Analyst  
 Security Controls Analyst  
 Third-Party Risk Analyst  
 Security Assurance Analyst  
 Cybersecurity Program Analyst  
 Junior Security Analyst  
 Audit Readiness Analyst

### 18.2 Work a junior analyst may perform

- Maintain asset, data, system, risk, obligation, supplier, and evidence inventories.
- Gather and organize evidence for scoped CSF outcomes.
- Review access, vulnerability, training, logging, backup, supplier, and incident samples.
- Document Profile status, gaps, limitations, owners, and action plans.
- Track corrective actions, exceptions, risk acceptances, and retests.
- Prepare clear dashboards and meeting materials without hiding uncertainty.
- Support exercises, incident timelines, lessons learned, and plan updates.
- Protect confidential information and follow authorization boundaries.

## 18.3 Portfolio proof

| Skill                    | Fictional portfolio item                                                |
|--------------------------|-------------------------------------------------------------------------|
| Scope                    | Profile scope statement and assumptions                                 |
| Core mapping             | All-outcome applicability and evidence matrix                           |
| Asset management         | System, data, supplier, and flow inventory                              |
| Risk                     | Risk register with appetite, tolerance, response, and residual decision |
| Profiles                 | Current and Target Profiles with prioritized gaps                       |
| Testing                  | Access, vulnerability, backup, logging, and supplier test sheets        |
| Incident response        | Synthetic timeline, evidence log, communication, and lessons            |
| Management communication | One-page dashboard and executive risk statement                         |

## 19. Fictional Laboratory and Portfolio

*A complete practice environment using synthetic information and authorized lab systems.*

Harbor Light Services is a fictional organization providing a customer portal, call center, cloud collaboration, payment integration, remote workforce, and supplier-hosted analytics. Every person, account, address, asset, event, customer record, and supplier is invented.

### Project 1 — Scope and context

Define mission, stakeholders, obligations, critical services, dependencies, exclusions, and owners.

### Project 2 — Asset and data map

Build inventories and an authorized data-flow diagram.

### Project 3 — Risk

Create a threat, vulnerability, likelihood, impact, treatment, and residual-risk register.

### Project 4 — Profiles

Create evidence-based Current and risk-based Target Profiles.

### Project 5 — Controls and tests

Design and execute fictional tests for access, vulnerabilities, logs, backups, and suppliers.

### Project 6 — Incident

Analyze synthetic events, declare an incident, preserve evidence, contain, eradicate, restore, and learn.

### Project 7 — Tools

Use three Chapter 16 tools in an isolated lab and record authorization, version, scope, findings, correction, and retest.

### Project 8 — Executive report

Prepare a dashboard, top-risk statements, action plan, decisions, and limitations.

**Portfolio ethics:** Label all work as fictional training. Never publish employer, client, patient, customer, employee, supplier, architecture, vulnerability, credential, or incident information without explicit authorization.

## 20. Thirty-Day Learning Plan

*A realistic month of official reading, practice, portfolio work, and interview preparation.*

| Week   | Focus                                                             | Required output                                              |
|--------|-------------------------------------------------------------------|--------------------------------------------------------------|
| Week 1 | CSF purpose, Core, six Functions, context, and assets             | Scope memo, stakeholder map, asset and data inventory        |
| Week 2 | Risk, Profiles, Tiers, governance, and supply chain               | Risk register, Current and Target Profiles, supplier tiering |
| Week 3 | Safeguards, monitoring, response, recovery, evidence, and testing | Five control tests, incident file, recovery evidence         |
| Week 4 | Tools, reporting, portfolio, and interviews                       | Sanitized portfolio, dashboard, practiced answers            |

### 20.1 Daily habit

Read one official NIST section or outcome group.

Explain it in plain language without changing its meaning.

Create one fictional evidence item.

Test its completeness, scope, date, ownership, and reliability.

Write one conclusion, corrective action, or lesson.

## 21. Interview Preparation

*Short, accurate answers for junior analysts and managers.*

### What is NIST CSF 2.0?

A flexible, outcome-focused framework that helps organizations understand, assess, prioritize, and communicate cybersecurity risk using the Core, Profiles, Tiers, and supporting resources.

### What are the six Functions?

Govern, Identify, Protect, Detect, Respond, and Recover.

### Why was Govern added?

It makes leadership accountability, policy, risk strategy, enterprise-risk integration, oversight, and supply-chain risk explicit.

### What is a Current Profile?

A description of Core outcomes a defined scope is currently achieving or attempting to achieve, including how or to what extent.

### What is a Target Profile?

The prioritized Core outcomes the organization selects for a defined future state based on mission, risk, obligations, stakeholders, and resources.

### What are Tiers?

Context for the rigor of cybersecurity risk governance and management practices: Partial, Risk Informed, Repeatable, and Adaptive.

### Does CSF certify compliance?

No. CSF alignment does not itself create legal compliance or NIST certification. Applicable obligations and implemented controls must be separately evaluated.

### How do you verify an outcome?

Define scope and criteria, evaluate control design, obtain a complete population, sample by risk, inspect and reperform, record exceptions, correct, retest, and state a supported conclusion.

### How should tools be used?

Only with authorization and as one evidence source. Validate coverage and results, protect outputs, correct confirmed gaps, and retest.

## How do you prioritize gaps?

Use mission impact, threat, likelihood, asset and supplier criticality, obligations, exposure, dependencies, existing controls, cost, feasibility, and risk appetite.

**Manager's 60-second answer:** I use CSF 2.0 to connect cybersecurity with business risk. We define scope and stakeholders, select applicable outcomes, build evidence-based Current and risk-based Target Profiles, prioritize gaps against appetite and obligations, fund action plans, test operating evidence, include suppliers, and report decisions and limitations clearly. Tools support the work, but people remain accountable for scope, judgment, correction, and residual risk.

## 22. Templates and Checklists

*Reusable structures for an approved organizational system.*

### 22.1 Profile record

- ✓ Scope, purpose, owner, sponsor, stakeholders, date, and review trigger
- ✓ Function, Category, and Subcategory identifier
- ✓ Applicability and rationale
- ✓ Current status, implementation, owner, evidence, test, exception, and limitation
- ✓ Target status and priority
- ✓ Gap, risk, action, interim protection, owner, resources, date, dependency, and retest
- ✓ Current and Target Tier context where useful
- ✓ Approval and version history

### 22.2 Risk register

- ✓ Objective, asset, service, data, supplier, and owner
- ✓ Threat, vulnerability, scenario, and affected CSF outcomes
- ✓ Existing controls and evidence
- ✓ Likelihood, impact, inherent risk, and method
- ✓ Response, action, owner, resources, date, and dependency
- ✓ Residual risk, appetite/tolerance comparison, and acceptance authority
- ✓ Indicator, review trigger, exception expiry, and retest

### 22.3 Control test sheet

- ✓ Outcome, risk, control, owner, frequency, systems, locations, and period
- ✓ Design criteria and expected evidence
- ✓ Complete population and completeness check
- ✓ Sample method and selected items
- ✓ Procedure, evidence inspected, reperformance, and result
- ✓ Exceptions, cause, impact, action, owner, date, and interim protection
- ✓ Retest, conclusion, limitations, reviewer, and approval

### 22.4 Supplier review

- ✓ Service, owner, criticality, access, data, locations, subcontractors, dependencies, and alternatives
- ✓ Due diligence, authenticity, secure development, vulnerabilities, resilience, incident history, and financial or operational concerns
- ✓ Contract requirements, evidence rights, notification, recovery, return/destruction, and exit
- ✓ Monitoring, findings, exceptions, corrective actions, exercises, incidents, changes, renewal, and termination

## 22.5 Manager readiness checklist

- ✓ Sponsor, roles, resources, policy, and risk strategy approved
- ✓ Scope, stakeholders, obligations, critical services, dependencies, and suppliers current
- ✓ Asset, data, system, service, identity, vulnerability, and risk populations reconciled
- ✓ Current and Target Profiles supported and approved
- ✓ Risk-based action plan funded and tracked
- ✓ Safeguard, monitoring, incident, and recovery evidence tested
- ✓ Supplier life-cycle controls operating
- ✓ Metrics connected to risk and outcomes
- ✓ Exceptions, acceptances, limitations, and retests visible to decision-makers



## 23. Glossary and Subject Index

*Plain-English definitions and a guide to major topics.*

**Category.** A group of related cybersecurity outcomes within a Function.

**Community Profile.** A published baseline of CSF outcomes for shared sector, technology, threat, or use-case needs.

**Core.** The hierarchy of Functions, Categories, and Subcategories that describes cybersecurity outcomes.

**Current Profile.** The outcomes a defined scope is currently achieving or attempting to achieve, including how or to what extent.

**Cybersecurity risk.** The possible effect of uncertainty on information and technology and the related organizational objectives.

**Function.** The highest CSF outcome level: Govern, Identify, Protect, Detect, Respond, or Recover.

**Implementation Example.** A notional, action-oriented illustration of one possible way to support a Core outcome.

**Informative Reference.** A mapping between a Core outcome and another standard, guideline, regulation, or source.

**Organizational Profile.** A mechanism for describing Current and/or Target cybersecurity posture using Core outcomes.

**Residual risk.** Risk remaining after controls and responses are considered.

**Risk appetite.** The broad amount and type of risk an organization is willing to pursue or retain.

**Risk tolerance.** Acceptable variation around specific objectives or performance.

**Subcategory.** A specific cybersecurity outcome within a Category.

**Target Profile.** The selected and prioritized outcomes a defined scope aims to achieve.

**Tier.** Context for the rigor of cybersecurity risk governance and risk-management practices.

### 23.1 Subject index

| Topic             | Chapters     | Topic                    | Chapters      |
|-------------------|--------------|--------------------------|---------------|
| Access control    | 6, 15–16, 22 | Metrics                  | 14, 17        |
| Asset inventory   | 5, 15, 22    | Open-source tools        | 16            |
| Audit readiness   | 14–15, 22    | Organizational Profiles  | 2–3, 10       |
| Compliance        | 1, 15        | Protect                  | 6             |
| Core              | 2, 4–9       | Recover                  | 9             |
| Detect            | 7            | Risk appetite            | 4, 12         |
| Evidence          | 14–16        | Risk assessment          | 5, 12, 22     |
| Govern            | 4, 12–13, 17 | Supply chain             | 4, 13, 15, 22 |
| Identify          | 5            | Tiers                    | 2, 11         |
| Incident response | 8, 15, 19    | Verification             | 14–16         |
| Junior analyst    | 18–21        | Vulnerability management | 5, 15–16      |

## 24. Official References and Further Study

*Current official NIST publications, tools, and project documentation used for verification.*

[NIST Cybersecurity Framework 2.0 — CSWP 29](#)

[NIST Cybersecurity Framework website](#)

[CSF 2.0 Reference Tool](#)

[CSF 2.0 Frequently Asked Questions](#)

[CSF 2.0 Profiles](#)

[CSF 2.0 Informative References](#)

[CSF 2.0 Resource and Overview Guide — SP 1299](#)

[CSF 2.0 Organizational Profiles Quick-Start Guide — SP 1301](#)

[CSF 2.0 Tiers Quick-Start Guide — SP 1302](#)

[CSF 2.0 Enterprise Risk Management Quick-Start Guide — SP 1303](#)

[CSF 2.0 Small Business Quick-Start Guide — SP 1300](#)

[NIST SP 800-53 Rev. 5](#)

[NIST SP 800-61 Rev. 3 — Incident Response](#)

[NIST SP 800-218 — Secure Software Development Framework](#)

[NIST NICE Workforce Framework](#)

**Final reminder:** The CSF Core is stable, while online Implementation Examples, Informative References, guidance, mappings, threats, technologies, and obligations can change. Verify current official NIST sources and organization-specific requirements before acting.